RINISHA

WHERE DESIGN MEETS PERFORMANCE

FREE CHECKLIST · INDIA 2026

Website Compliance Checklist

The 8 things every Indian business website should have under India's data protection and consumer laws, plus what most lists miss. Written in plain language, so you can check your own site in 15 minutes.

MAX PENALTY

₹250 cr

DPDP Act, for failing to protect personal data.

DEADLINE

13 May 2027

Core DPDP duties and penalties apply from this date.

APPLIES TO

You

Any business that collects names, phones, emails or tracking data online.

☐ **How to use this:** open your website on your phone, go through each item, and tick the box only if you can actually find it on your site today. Anything unticked is your to-do list.

LAWS THIS CHECKLIST IS BASED ON

- Digital Personal Data Protection Act, 2023
- DPDP Rules, 2025 (notified 13 Nov 2025)
- IT (Reasonable Security Practices & SPDI) Rules, 2011
- Consumer Protection (E-Commerce) Rules, 2020
- CCPA Guidelines on Dark Patterns, 2023
- CERT-In Directions, April 2022

General information only, not legal advice. Laws and dates are as of October 2026; the government has proposed bringing the DPDP deadline forward, so check the latest notification and speak to a lawyer for your specific business.

1 Privacy Policy (Privacy Notice)

Saaf bhaasha mein batao: kaunsa data, kyon, kitne din, kisse share

Before you collect anyone's personal data, you must tell them what you are collecting and why, in a notice they can understand on its own.

- [ ] A **Privacy Policy page** is linked in the footer of every page and next to every form.
- [ ] It lists **each type of data** you collect (name, phone, email, address, IP, cookies, payment info).
- [ ] It says the **specific purpose** for each (order delivery, support, marketing, analytics).
- [ ] It says **how long** you keep the data and **who you share it with** (payment gateway, courier, CRM, ad platforms).
- [ ] It explains how users can **withdraw consent, use their rights** and **complain to the Data Protection Board**.
- [ ] It describes the **security practices** you follow, and shows a "last updated" date.

DPDP Act s.5 · DPDP Rules r.3 · IT Rules 2011 r.4

2 Consent, done properly

Pehle se tick? Nahi chalega. Waapas lena bhi utna hi aasaan.

Consent must be free, specific, informed and given by a clear action. Silence or a pre-ticked box is not consent.

- [ ] **No pre-ticked boxes** on any form: not for marketing, not for WhatsApp updates, not for purchases.
- [ ] Marketing consent is **separate** from the consent needed to deliver the service.
- [ ] Users can **withdraw consent as easily** as they gave it (an unsubscribe link, a settings toggle).
- [ ] You **keep a record** of who consented, to what, and when.

DPDP Act s.6 · DPDP Rules r.3 · E-Commerce Rules r.4(9)

3 Grievance Officer & contact

Shikaayat sunne wale ka naam aur contact, website par saaf

People must know exactly whom to contact about their data or an order, and get an answer in time.

- [ ] The **name, designation and contact** (email + phone) of a Grievance Officer or the person who answers data questions is on the website.
- [ ] There is a simple way to **raise a complaint** (form or email), ideally with a ticket number.
- [ ] Data complaints are answered within **90 days** at the latest (DPDP); online-shopping complaints are acknowledged in **48 hours** and resolved in **1 month**.

DPDP Act s.8(9), s.8(10) · DPDP Rules r.9, r.14 · IT Rules 2011 r.5(9) · E-Commerce Rules r.4

4 Cookies & tracking

Visitor ko batao ki aap track kar rahe ho, aur uski marzi lo

Analytics tags and ad pixels collect personal data such as IP address, device and behaviour. That needs notice and consent like any other data.

- [ ] A **cookie banner** appears on the first visit, with **Accept, Reject and Choose** options that are equally easy to click.
- [ ] Non-essential trackers (ads, analytics) **load only after** the visitor agrees.
- [ ] Your Privacy Policy **names the tools** you use and why (analytics, ads, chat widgets).
- [ ] Visitors can **change their choice** later (a "Cookie settings" link in the footer).

The DPDP Act has no cookie-specific rule; this is how its notice and consent rules apply to trackers.

`DPDP Act s.5, s.6` `Best practice`

5 Terms & Conditions

Service ke niyam, likhit mein. Kal jhagda ho, toh aap surakshit.

Written terms protect you in a dispute and set clear expectations for customers.

- [ ] A **Terms & Conditions** page covers your services, pricing and payment, cancellations, and limits of liability.
- [ ] It states the **governing law and jurisdiction** (your city's courts) and how disputes are handled.
- [ ] If users can post content (reviews, comments, listings), it includes **user rules** and how you handle complaints.
- [ ] Users **agree to it** at sign-up or checkout (an unticked box or a clear "By continuing..." line).

`Contract Act, 1872` `IT Intermediary Rules 2021 r.3 (if users post content)`

6 Selling online? Policies + business details

Return, refund, shipping. Legal naam, pata, contact. Sab website par.

Every e-commerce seller must show clear consumer information before the customer pays.

- [ ] **Return, Refund, Exchange, Shipping/Delivery** and **Warranty** policies, including who pays for return shipping.
- [ ] Your **legal business name**, registered address, customer care contact and Grievance Officer details.
- [ ] The **total price with a break-up** of all charges before payment, plus accepted payment modes.
- [ ] Product **country of origin** and other mandatory product details where they apply.
- [ ] **No dark patterns:** no fake countdowns, hidden charges, items sneaked into the cart, or fake reviews.

`E-Commerce Rules 2020 r.4-6` `CCPA Dark Patterns Guidelines 2023`

7 Children's data (under 18)

18 se kam umar? Maata-pita ki permission zaroori.

Under the DPDP Act, anyone under 18 is a child. Their data has the strictest rules.

- [ ] Sign-up or enquiry forms **ask for age** (or date of birth) where children could use your service.
- [ ] For users under 18, you get **verifiable parental consent** before collecting their data.
- [ ] **No tracking, behavioural monitoring or targeted ads** aimed at children.
- [ ] Nothing you do with a child's data is likely to **harm their well-being**.

`DPDP Act s.9` `DPDP Rules r.10` `Penalty up to ₹200 cr`

8 Data security & breach response

SSL lagao, data surakshit rakho. Leak hua? Dono ko batao.

You must take reasonable security safeguards. This carries the highest penalty in the law, up to ₹250 crore.

- [ ] The whole site runs on **HTTPS** (valid SSL certificate, no "Not secure" warning).
- [ ] Form entries, orders and customer lists are stored with **access control** (only the people who need them), strong passwords and 2-step login.
- [ ] Sensitive data is **encrypted or masked**, with regular **backups**, and access **logs kept for at least 1 year**.
- [ ] Vendors that handle your data (hosting, CRM, agencies) have a **contract that requires security**.
- [ ] A written **breach plan**: tell affected users without delay, and inform the Data Protection Board, with a detailed report **within 72 hours**.
- [ ] Cyber incidents are reported to **CERT-In within 6 hours** of noticing them.

`DPDP Act s.8(5), s.8(6)` `DPDP Rules r.6, r.7` `CERT-In Directions 2022`

Your score

Count your ticks across checks 1–8

30–36 ticks: great shape. Do the "beyond the 8" page next.
18–29 ticks: fix the gaps before May 2027.
Under 18: your website is collecting data without the basics. Start with checks 1, 2 and 8.

Aur ye bhi poori list nahi hai...

These are less visible on the website, but just as required.

User rights

Let people ask for a summary of their data, correct it, delete it, and name a nominee. Publish how to make these requests.

DPDP Act s.11-14

Delete when done

Erase personal data once its purpose is over or consent is withdrawn, unless a law requires you to keep it. Ask your processors to delete it too.

DPDP Act s.8(7) Rules r.8

Keep records

Keep consent records, and keep logs and related data for at least one year so you can investigate incidents.

DPDP Rules r.6, 7th Schedule

Large platforms

Large e-commerce, gaming and social media platforms must erase inactive users' data after 3 years, warning them 48 hours before.

DPDP Rules r.8, 3rd Schedule

KEY DATES

DONE

11 Aug 2023

DPDP Act passed.

DONE

13 Nov 2025

DPDP Rules notified; Board provisions in force.

DEADLINE

13 May 2027

Notice, consent, security, breach, children's data and penalties all apply.*

MAXIMUM PENALTIES UNDER THE DPDP ACT

FAILURE	UP TO
Not taking reasonable security safeguards to prevent a data breach	₹250 crore
Not informing the Board and affected users about a breach	₹200 crore
Breaking the rules on children's data	₹200 crore
Extra duties of Significant Data Fiduciaries	₹150 crore
Any other provision of the Act or Rules	₹50 crore

**In January 2026 the government proposed bringing the deadline forward. As of October 2026 no change has been notified, so check before you plan.*

RINISHA

WHERE DESIGN MEETS PERFORMANCE

SHURU SE SAHI

Want a website that's compliant from day one?

Rinisha builds fast, well-designed websites for Indian businesses, with these checks built in from the start: not added later as an afterthought.

- Privacy Policy, Terms and store policies drafted for your business
- Consent-first forms, no pre-ticked boxes
- Cookie banner with tracking that waits for consent
- Grievance Officer and contact details in the right places
- HTTPS, secure forms and backups
- Compliance review of your existing website

DM us on Instagram or visit our website

rinisha.com →

abhi@rinisha.com rinisha.com

This checklist is general information to help you review your website, not legal advice. Policies must be written for your actual business, so have them reviewed by a qualified lawyer. Information as of October 2026.

© RINISHA